MSM ACADEMY

SECTION 6

Risk assessment, treatment and the SoA



6.1 Risk in ISO/IEC 27001
6.2 Risk criteria and method
6.3 Identifying and analysing risks
6.4 Evaluating and treating risks
6.5 The SoA and the treatment plan
6.6 Risk in operation

MSM ACADEMY

SECTION 6 · LESSON 6.1

Risk in ISO/IEC 27001

Two kinds of risk, one vocabulary, one process



LESSON 6.1

Two kinds of risk

Clause 6 asks for both

6.1.1 Risks and opportunities for the ISMS itself: will the system achieve its outcomes?

6.1.2 Information security risks: loss of confidentiality, integrity or availability of information in scope

- This section teaches the method for the second; the first is planned with the ISMS (Section 4)

LESSON 6.1

The vocabulary

Term	Meaning in practice
Risk criteria	The rules for judging risk: how to assess it and when it is acceptable
Risk owner	The person accountable for a risk, with the authority to manage it
Risk appetite	How much and what kind of risk the organization is willing to take, set by top management
Risk source and scenario	What can give rise to risk, and the chain of events from cause to consequence
Retention and acceptance	Retention is a treatment choice; acceptance is the owner’s decision on residual risk

LESSON 6.1 · PROCESS

The risk process end to end

1	**Criteria**	Set assessment and acceptance criteria	6.1.2 a
2	**Assess**	Identify, analyse and evaluate risks	6.1.2 c–e
3	**Decision 1**	Is the assessment good enough to decide? If not, iterate	27005 5.1
4	**Treat**	Choose options, determine controls, check Annex A, SoA, plan	6.1.3 a–e
5	**Decision 2**	Is the residual risk acceptable? Owners approve and accept	6.1.3 f
6	**Operate**	Assess at intervals and on change; implement; monitor	8.2 · 8.3

LESSON 6.1

What the standard leaves to you

Requirements, not a recipe

- No prescribed method, scale or matrix, and no requirement to start from an asset list
- The method must give consistent, valid and comparable results (6.1.2 b)
- Align it with the organization’s wider risk management, and document the approach

Risk foundations: two perspectives

Implementer's view

- Agree the vocabulary before the first workshop
- Choose a method the business already understands
- Document the approach and its reasons

Auditor's view

- Ask which method is used, and why
- Test that terms are used consistently
- Look for both kinds of Clause 6 risk

LESSON 6.1 · RECAP

Lesson 6.1 recap

- 6.1.1 risks to the ISMS; 6.1.2 information security risks
- Retention is a treatment choice; acceptance is the owner’s decision
- Two decision points: is the assessment enough, is the residual acceptable
- No prescribed method; results must be consistent, valid, comparable

LESSON 6.1 · KNOWLEDGE CHECK

Check your understanding

An organization assesses information security risks with a detailed register, but nobody has considered whether the ISMS project has the people it needs. What is missing?

A Clause 6.1.1: risks and opportunities for the ISMS itself

B Nothing: the register covers Clause 6 completely

C An asset inventory before the register

D A second risk register for each department

Check your understanding

An organization assesses information security risks with a detailed register, but nobody has considered whether the ISMS project has the people it needs. What is missing?

A **Clause 6.1.1: risks and opportunities for the ISMS itself**

B Nothing: the register covers Clause 6 completely

C An asset inventory before the register

D A second risk register for each department

Answer: A

Clause 6.1.1 covers risks and opportunities for the ISMS itself, such as resourcing. The 6.1.2 register does not address them.

MSM ACADEMY

SECTION 6 · LESSON 6.2

Risk criteria and method

Decide the rules before you play



LESSON 6.2

Two sets of criteria

Both required by 6.1.2 a)

1. Criteria for performing assessments: how consequence, likelihood and risk level are judged

2. Risk acceptance criteria: which levels are acceptable, and who may accept them

- Risk appetite is set by top management; the criteria are approved by authorized management and reviewed

LESSON 6.2

Consequence and likelihood scales

Level	Consequence (impact)	Likelihood (frequency-anchored)
1	Very low: no disruption, no data loss	Rare: less than once in 10 years
2	Minor: brief disruption, non-sensitive data	Unlikely: once in 3 to 10 years
3	Moderate: important data or service affected	Possible: once in 1 to 3 years
4	Significant: sensitive data compromised, penalties	Likely: about once a year
5	Extreme: critical data or systems lost, severe damage	Almost certain: several times a year

Acceptance authority: the MSM toolkit model

Risk level	Acceptance	Who may accept
Low (1–3)	Acceptable	Risk owner
Medium (4–6)	Acceptable with conditions	Risk owner, reported to ISMS committee
High (8–12)	Treat; temporary retention only with a plan	Top management
Very high (15–25)	Treat as priority; exceptional override only	Top management, written justification and expiry
Consequence 5	Any score	Top management decision

LESSON 6.2

Asset-based or event-based?

Two starting levels for the same risks

- Event-based: start from strategic scenarios: risk sources, events, consequences to the business
- Asset-based: start from operational scenarios: assets, threats, vulnerabilities
- Both can describe the same risk; ISO/IEC 27001 does not require an asset-based method

LESSON 6.2

Consistent, valid, comparable

Making 6.1.2 b) real

- Consistent: the same risk, assessed again, gives a similar result
- Comparable: different risks of equal size come out at equal levels
- Valid: results match reality; team assessment and calibration help, and the rationale is recorded

Criteria: two perspectives

Implementer's view

- Agree criteria and authority with top management first
- Anchor scales to frequencies and real effects
- Record who may accept what

Auditor's view

- Ask for the approved criteria and their date
- Test two assessors on the same risk
- Compare each acceptance with the authority model

LESSON 6.2 · RECAP

Lesson 6.2 recap

- Two sets of criteria: assessment and acceptance
- Frequency-anchored, unambiguous scales; score current risk
- An explicit authority model: who may accept which level
- Consistent, valid, comparable through teams, calibration and rationale

Check your understanding

A department head accepts a High residual risk on her own authority. Under the MSM authority model, what is the issue?

A None: risk owners may accept any residual risk

B The risk should have been shared instead

C High risks need top-management approval and a treatment plan to be retained

D Only the ISMS manager may accept risks

Check your understanding

A department head accepts a High residual risk on her own authority. Under the MSM authority model, what is the issue?

A. None: risk owners may accept any residual risk

B. The risk should have been shared instead

C. **High risks need top-management approval and a treatment plan to be retained**

D. Only the ISMS manager may accept risks

Answer: C

Under the model, High risks may be retained only temporarily, with top-management approval and a dated treatment plan. The department head lacked that authority.

MSM ACADEMY

SECTION 6 · LESSON 6.3

Identifying and analysing risks

6.3

From scenarios to scores

LESSON 6.3

Identifying risks to C, I and A

Look widely, then describe precisely

- Sources: human, technical, environmental, whether or not under the organization’s control
- Inputs: context issues, interested-party requirements, assets and processes, past incidents
- Include interfaces outside the scope; keep specific risks separate from aggregated ones

LESSON 6.3

Assigning risk owners

Authority, not technical familiarity

- A position that lets them actually exercise authority over the risk
- Enough understanding to make informed decisions
- Assigned during the assessment, told in writing, reassigned when people change

LESSON 6.3

Analysing consequences and likelihood

Enough precision to decide, no more

- Consequence: what losing C, I or A would mean for the business
- Likelihood: motive and capability for deliberate sources; location and history for accidental ones
- Account for existing controls; rough estimates are often enough to decide

LESSON 6.3

The risk register

Column group	What it records
Identification	Risk ID, scenario, source, vulnerability, property affected (C, I, A), existing controls
Analysis	Consequence, likelihood, current score and level
Evaluation	Result of the acceptance criteria (accept / treat), priority, rationale
Treatment	Owner, option, controls, planned residual score and level
Acceptance	Required authority, accepted by, authority level, date, conditions, authority check

LESSON 6.3

Running a risk workshop

Facilitate, do not dictate

- Prepare: scenarios, scales and examples sent in advance
- Assess in a team: owners, process experts, security
- Calibrate against the scale wording; investigate disagreement, record the reasoning

Role play: “Everything is a five”



Simon Hartley Head of Operations, Northfield Logistics

“Every one of these could ruin us. Put them all at five for consequence and five for likelihood.”

YOU

Your move: Keep his concern, but bring the scoring back to the criteria. What do you say?

LESSON 6.3 · ROLE PLAY

One way to say it

“You’re right that they matter. If everything is a five, though, we can’t tell which to fix first. Let’s take this one: how often has it happened here, or somewhere like us? The scale says ‘about once a year’ is a four.”

Why it works

- Takes the concern seriously first
- Explains why equal scores defeat the purpose
- Moves to evidence and the scale wording

Assessment: two perspectives

Implementer's view

- Assess in teams with owners present
- Give every risk an owner with real authority
- Record reasoning, not just scores

Auditor's view

- Sample risks and ask the owner about them
- Check scores against the scale wording
- Look for owners who cannot exercise authority

LESSON 6.3 · RECAP

Lesson 6.3 recap

- Identify widely: all source types, interfaces, specific risks kept separate
- Owners with real authority, assigned and told in writing
- Analyse current risk with enough precision to decide
- The register records identification to acceptance, with an authority check

LESSON 6.3 · KNOWLEDGE CHECK

Check your understanding

Who is usually the best risk owner for a risk to payroll data integrity?

A The IT administrator who manages the payroll server

B The finance manager accountable for payroll, with authority over the process

C The external auditor

D The person who found the vulnerability

Check your understanding

Who is usually the best risk owner for a risk to payroll data integrity?

A. The IT administrator who manages the payroll server

B. The finance manager accountable for payroll, with authority over the process

C. The external auditor

D. The person who found the vulnerability

Answer: B

A risk owner needs accountability and authority to manage the risk. The finance manager owns the payroll process; IT supports it.

MSM ACADEMY

SECTION 6 · LESSON 6.4

Evaluating and treating risks

6.4

From scores to decisions

LESSON 6.4

Evaluating against the criteria

Compare, decide, prioritize

- Compare each current level with the acceptance criteria: accept or treat
- Take account of confidence in the assessment and of frequent small events adding up
- Investigate where the owner’s view and the assessed level disagree; then prioritize

LESSON 6.4

Four treatment options

Option	What it means	Toolkit label
Modify	Change the likelihood or the consequence with controls	Modify (reduce)
Retain	Keep the risk by informed choice, within criteria; can be time-limited	Retain
Avoid	Stop, or do not start, the activity that creates the risk	Avoid
Share	Agree with another party to take part of the risk; a control is still needed	Share (transfer)

LESSON 6.4

Determining the controls

From any source; Annex A checks completeness

- Necessary means more than a negligible effect on likelihood or consequence
- Existing controls are included only if a risk needs them; custom controls are worded precisely
- Compare with Annex A risk by risk, in the assessment, to catch omissions

LESSON 6.4

Worked example

Step	Northfield Logistics: shared warehouse tablets
Scenario	Shared tablet logins let anyone see customer delivery details
Analysis	Consequence 3, likelihood 4: current score 12, High
Evaluation	Above acceptance criteria: treat, priority 1
Treatment	Modify: individual logins (5.16), device management (8.1)
Residual	Consequence 3, likelihood 2: score 6, Medium; owner may accept, reported to the ISMS committee

Treatment: two perspectives



Implementer's view

- Choose options from evidence and cost
- Determine controls from any source; check Annex A per risk
- Record the rationale for each choice



Auditor's view

- Trace a risk to its controls and back
- Ask why an option was chosen
- Look for controls added without a risk

LESSON 6.4 · RECAP

Lesson 6.4 recap

- Evaluate: accept or treat, then prioritize
- Four options: modify, retain, avoid, share
- Acceptance is the owner’s decision on what remains, not an option
- Necessary controls from any source; Annex A checked per risk

LESSON 6.4 · KNOWLEDGE CHECK

Check your understanding

A company buys cyber insurance for ransomware and records the risk as fully transferred, with no other controls. What is wrong?

A Nothing: insurance removes the risk

B Insurance is a form of avoidance

C Insurance can only be used for Low risks

D Sharing still needs at least one control; insurance does not remove the operational risk

Check your understanding

A company buys cyber insurance for ransomware and records the risk as fully transferred, with no other controls. What is wrong?

A. Nothing: insurance removes the risk

B. Insurance is a form of avoidance

C. Insurance can only be used for Low risks

D. Sharing still needs at least one control; insurance does not remove the operational risk

Answer: D

Sharing distributes part of the risk, usually the financial consequence. At least one control is still required, and the operational risk remains.

MSM ACADEMY

SECTION 6 · LESSON 6.5

The SoA and the treatment plan

Recording decisions and getting them approved

6.5

LESSON 6.5

What the SoA must contain

6.1.3 d)

- The controls determined as necessary through risk treatment, from Annex A or other sources
- The justification for including them, and whether they are implemented
- The justification for excluding any Annex A control

LESSON 6.5

The SoA template

Column	Rule
Control ID	Stored as text, so 5.10 never becomes 5.1
Necessary (Yes / No)	Decided by the risk assessment
Justification	Inclusion: risk IDs or the common statement. Exclusion: Annex A controls only
Implementation status	Implemented, Partially implemented, Not implemented; necessary controls only
Other-source controls	Separate sheet, with custom-control wording fields

LESSON 6.5

Justifying exclusions

From the risk assessment, never from a slogan

- A control is excluded because no risk in scope needs it
- The justification points to that result
- “We are a cloud company” is not a justification if the scope contains offices

LESSON 6.5

The risk treatment plan

Field	Why it matters
Option, controls, references	What will be done, with correct control references
Rationale and expected benefit	Why this treatment, and what it should achieve
Owner, resources, constraints, dates	Who, with what, and by when
Performance indicator and reporting	How we will know it worked
Planned residual risk and owner approval	What remains, and who accepted it

LESSON 6.5

Risk owner approval and residual acceptance

6.1.3 f)

- Owners approve the plan and decide on the planned residual risk at approval
- Within their authority; conditions recorded; time limits where retention is temporary
- Outside normal criteria: explicit justification and higher authority; reassess after implementation

Role play: “I’ll just accept it”



Helen Brook Finance Manager, Northfield Logistics

“The fix costs too much this year. I own the risk, so I’ll just accept it. It’s High, but we’ve lived with it.”

YOU

Your move: Respect her ownership, and explain the authority model. What do you say?

LESSON 6.5 · ROLE PLAY

One way to say it

“You do own it, and cost is a fair reason. For a High risk, though, our criteria need top management to agree, for a set period, with a plan. Shall we take it to them together, with your budget reasoning?”

Why it works

- Confirms her ownership and her reasoning
- Explains the rule as the organization’s own criteria
- Offers a route: escalate together, time-limited, with a plan

SoA and plan: two perspectives

Implementer's view

- Keep necessity and status separate
- Get owner approval and acceptance at the same time
- Record conditions and expiry dates

Auditor's view

- Trace SoA lines to risks and the plan
- Check acceptance against the authority model
- Challenge exclusions against the scope

LESSON 6.5 · RECAP

Lesson 6.5 recap

- SoA: necessary controls from any source, justified, with status
- Exclusions justified by the risk assessment
- Treatment plan with rationale, indicators and owner approval
- Residual risk accepted at approval, within authority

Check your understanding

An SoA marks control 7.4 “Necessary: No” and “Status: Implemented”. What is the problem?

A. None: implemented controls can be unnecessary

B. The control must be removed from the building

C. Status applies only to necessary controls; if it is needed, necessity must say Yes

D. The SoA should not list Annex A controls

Check your understanding

An SoA marks control 7.4 “Necessary: No” and “Status: Implemented”. What is the problem?

A. None: implemented controls can be unnecessary

B. The control must be removed from the building

C. **Status applies only to necessary controls; if it is needed, necessity must say Yes**

D. The SoA should not list Annex A controls

Answer: C

Implementation status is recorded only for necessary controls. Either the control is needed for a risk, and necessity is Yes, or it is excluded with a justification.

MSM ACADEMY

SECTION 6 · LESSON 6.6

Risk in operation

Keeping risk alive

6.6

LESSON 6.6

Assessing at planned intervals and on change

8.2

- A schedule, and evidence that assessments follow it
- For each significant change: assess, or record why it is not significant
- Triggers include changes in the threat landscape; time assessments for the budget cycle

LESSON 6.6

Implementing the plan and keeping results

8.3

- Implement the plan; retain results, including evidence that controls change the risk
- Keep previous versions: history is evidence
- Monitor retained and accepted risks, singly and together

LESSON 6.6

Risk in management review and audit

Communication runs both ways

- Management review considers risk results and the plan’s status (9.3.2 f)
- Communicate with owners both ways; share sensitive risk details on a need-to-know basis
- A risk committee can debate treatment and acceptance

LESSON 6.6 · EXERCISE

Exercise: from risk to SoA line

Northfield Logistics:

1 Each morning, the customer address list is emailed to drivers' personal phones. It happens daily.
2 Ransomware could stop the dispatch system for days; a similar firm was hit last year. Backups exist but are untested.

Score both risks, choose a treatment, write one SoA line for each, and name who must accept the residual risk.



Pause the video

Then compare with the model answer.

LESSON 6.6 · MODEL ANSWER

Model answer: from risk to SoA line

Risk 1	C3 × L4 = 12 High · Modify · SoA 5.14: Necessary Yes, R-01, Not implemented · residual 6: owner accepts, reports to committee
Risk 2	C5 × L2 = 10 High · Modify · SoA 8.13: Necessary Yes, R-02, Partially implemented · residual 5 · consequence 5: top management decides
Why	Scores follow the scale wording; authority follows the model, including the consequence override

The score sets the treatment; the authority model sets who may accept what remains.

LESSON 6.6

Common pitfalls

What auditors find most often

- Controls chosen first, risks written to fit
- Owners without authority, or acceptance beyond it
- An SoA copied from a template, unconnected to the register
- A register that never changes after certification

Operation: two perspectives

Implementer's view

- Schedule assessments and evidence them
- Keep history; monitor accepted risks
- Feed results to management review

Auditor's view

- Ask for the schedule and the last change assessment
- Compare register versions over time
- Trace management review back to the register

LESSON 6.6 · RECAP

Lesson 6.6 recap

- Assess on schedule and on significant change
- Implement the plan; keep results and history
- Monitor retained and accepted risks
- Feed risk into management review; communicate both ways

Check your understanding

A company migrated its main system to a new cloud provider. No risk assessment was done and nothing records why. What is the best assessment against 8.2?

A Conforming, because the annual assessment is next month

B A concern: a significant change needs an assessment, or a recorded reason why it is not significant

C Conforming, if the provider is certified

D Only a 6.3 issue

Check your understanding

A company migrated its main system to a new cloud provider. No risk assessment was done and nothing records why. What is the best assessment against 8.2?

A. Conforming, because the annual assessment is next month

B. A concern: a significant change needs an assessment, or a recorded reason why it is not significant

C. Conforming, if the provider is certified

D. Only a 6.3 issue

Answer: B

8.2 requires assessment when significant changes occur. Without an assessment or a recorded reason the change was not significant, the requirement is not shown to be met.

SECTION 6 · SUMMARY

Risk in one view

- Criteria first, including who may accept what
- Identify, analyse, evaluate: current risk, real owners
- Treat: four options, necessary controls from any source, SoA and plan
- Approve, accept within authority, and keep it running

MSM ACADEMY

SECTION 6 COMPLETE

Next: Section 7

Documented information and the ISMS toolkits

